

Autenticación de APIs

Tokens, OAuth 2.0, JWT y controles de acceso en APIs.

Autenticación vs autorización

La autenticación demuestra identidad; la autorización determina qué puede acceder esa identidad.

OAuth 2.0 y tokens

Los access tokens son comunes. QA debe validar tokens ausentes, inválidos, expirados, scopes incorrectos y renovación cuando aplique.

JWT

JWT es un formato de token. Valide firma, expiración, claims y comportamiento de la API; decodificar el payload no demuestra validez.

QA Tip

Incluya pruebas negativas de autenticación en toda API protegida.

Official: <https://datatracker.ietf.org/doc/html/rfc6749>